

Security Architecture Document

Enhancing Security in Messaging Applications

Spinnaker Analytics
23 June 2026

Table of Contents

1. Executive Summary
2. Existing Architecture Review
3. Threat Model
4. Enhanced Security Architecture
5. Secure Messaging Flow
6. Secure Voice Call Flow
7. Secure File Transfer Flow
8. Key Management Architecture
9. Security Layers
10. Conclusion

1. Executive Summary

- This document outlines a comprehensive security architecture for a modern messaging application, designed to protect user communications through end-to-end encryption, robust authentication mechanisms, and privacy-by-design principles.
- The architecture is based on the Signal Protocol, industry-standard encryption algorithms, and proven security frameworks.
 - The proposed security model ensures that:
 - All message content remains encrypted end-to-end
 - Voice calls and file transfers are protected with military-grade encryption
 - User authentication uses multi-factor mechanisms including biometrics
 - Minimal data retention policies protect user privacy
 - Continuous monitoring and incident response procedures detect threats
- This architecture balances security, usability, and scalability while adhering to privacy regulations and best practices.

2. Existing Architecture Review

2.1 Current System Components

- The baseline messaging application consists of the following components:
 - Client Application (Android/iOS)
 - Backend Server Infrastructure
 - User Database
 - Message Storage (encrypted at rest)
 - Authentication System

2.2 Identified Gaps

- The current architecture requires enhancement in the following areas:
 - Insufficient end-to-end encryption for all communication types
 - Limited key management and rotation mechanisms
 - Basic authentication without modern MFA options
 - Absence of Perfect Forward Secrecy (PFS)
 - Inadequate monitoring and incident response capabilities
 - Missing privacy-by-design data retention policies

3. Threat Model

3.1 Primary Threats

- The architecture addresses the following threat vectors:
 - Man-in-the-Middle (MITM) Attacks: Unauthorized interception of communications
 - Server Compromise: Attacker access to backend infrastructure
 - Metadata Harvesting: Collecting communication patterns and timing information
 - Credential Theft: Stealing user credentials through phishing or social engineering
 - Device Compromise: Malware or unauthorized access to client devices
 - Key Compromise: Exposure of encryption or authentication keys
 - Replay Attacks: Reusing captured messages or authentication tokens

3.2 Mitigation Strategies

- Each threat is mitigated through specific architectural controls and cryptographic mechanisms detailed in subsequent sections of this document.

3.3 STRIDE Threat Analysis

The following STRIDE analysis formally categorizes and addresses security threats:
STRIDE Threat Model Analysis

Threat Category	Specific Threat	Example Scenario	Mitigation Strategy
Spoofing	Account Impersonation	Attacker impersonates legitimate user	MFA (TOTP), Biometric authentication, Device registration
Tampering	Message Modification	Attacker modifies message in transit	HMAC-SHA256, TLS 1.3, End-to-end signatures
Repudiation	User Denies Action	Sender denies sending message	Audit logs, Server-side message receipt logs
Information Disclosure	Message Interception	Network eavesdropping on communications	Signal Protocol E2E encryption, TLS 1.3, AES-256-GCM
Denial of Service	Service Flooding	Attacker floods server with requests	Rate limiting, DDoS protection, Automated threat detection
Elevation of Privilege	Unauthorized Admin Access	Regular user gains admin rights	RBAC enforcement, Principle of least privilege, Audit logging

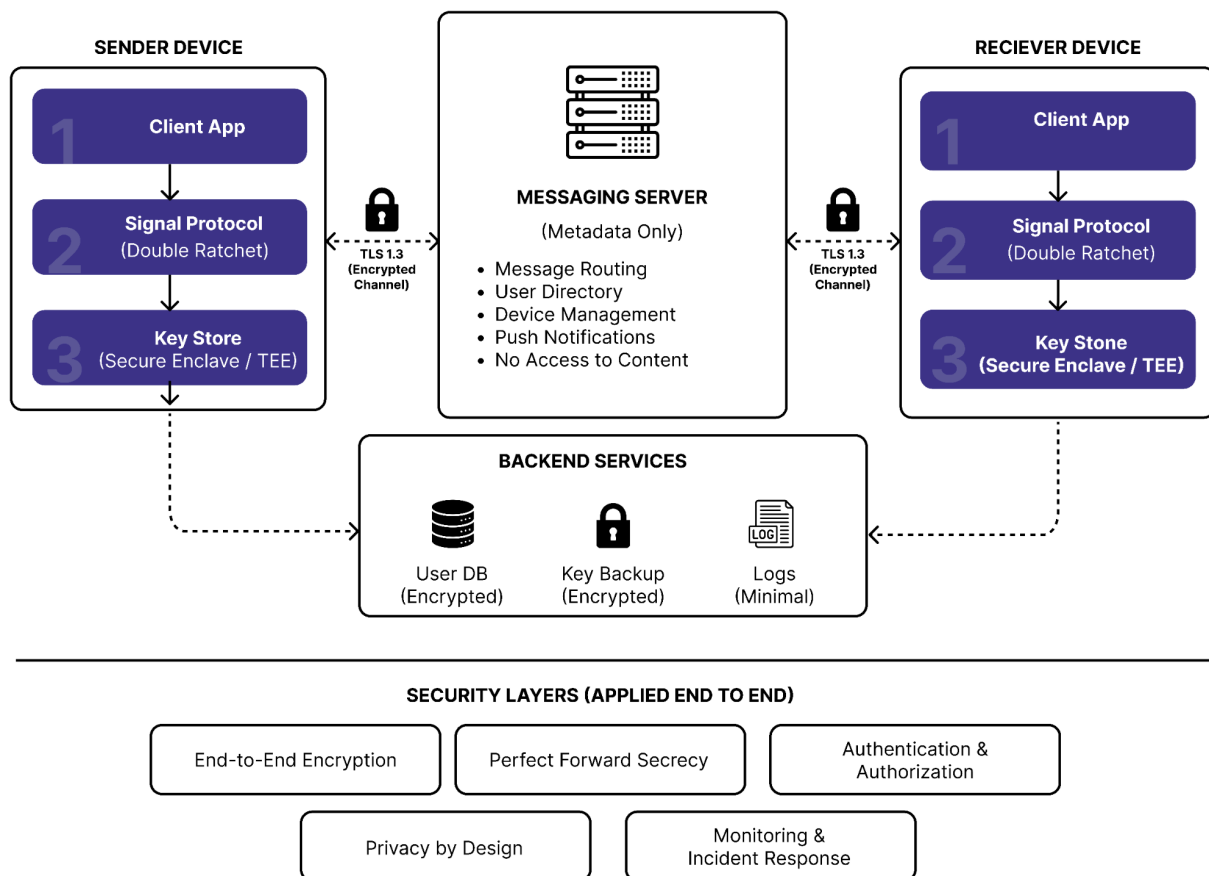
This STRIDE analysis ensures systematic coverage of the threat landscape and demonstrates that appropriate mitigations are in place for each threat category.

4. Enhanced Security Architecture

4.1 Architecture Overview

The enhanced security architecture implements a defense-in-depth approach with multiple layers of protection. Each communication type (messaging, voice calls, file transfers) is protected with appropriate encryption protocols and key management practices

Figure 1 – High-Level Security Architecture



The architecture demonstrates end-to-end encrypted communication between sender and receiver devices through a metadata-only messaging server. TLS 1.3 protects transport channels while Signal Protocol provides application-layer encryption.

4.2 Core Components

Component	Purpose
Signal Protocol	End-to-end encryption for messages, calls, and file transfers
X3DH	Secure key exchange protocol for establishing shared secrets
Double Ratchet	Key derivation and rotation with forward secrecy
SRTP	Secure Real-time Transport Protocol for voice calls
AES-256-GCM	Symmetric encryption for files and sensitive data
TLS 1.3	Secure communication channel between client and server
HMAC-SHA256	Message authentication and integrity verification

4.3 Security Principles

- Zero Knowledge: Server cannot access user content
- End-to-End Encryption: All communications encrypted at source
- Perfect Forward Secrecy: Compromise of long-term keys does not reveal past communications
- Privacy by Design: Minimal data collection and retention
- Multi-Layer Security: Defense in depth with overlapping protection mechanisms

4.4 Security Assumptions and Trust Boundaries

The following assumptions define the scope and boundaries of this security architecture:

Trust Assumptions

- Mobile devices are not rooted (Android) or jailbroken (iOS)
- Secure hardware keystore (TEE/Secure Enclave) is available on client devices
- TLS certificates are properly validated and trusted
- Users protect their credentials and maintain device security
- Network infrastructure (ISPs, WiFi providers) is not compromised
- Endpoint malware at the application layer is outside the scope of this architecture

Non-Assumptions

- This architecture does NOT assume protection against device root access
- This architecture does NOT assume protection against supply-chain compromises
- This architecture does NOT provide security against quantum computing threats (future consideration)
- This architecture does NOT protect users who share their credentials

Trust Boundaries

- The architecture establishes clear trust boundaries:
 - **Trusted:** Client application, user devices, Signal Protocol libraries, TLS implementation
 - **Untrusted:** Network infrastructure, server storage, third-party integrations
 - **Semi-Trusted:** Server infrastructure (processes metadata only; cannot access encrypted content)
 -

Architecture Summary Table:

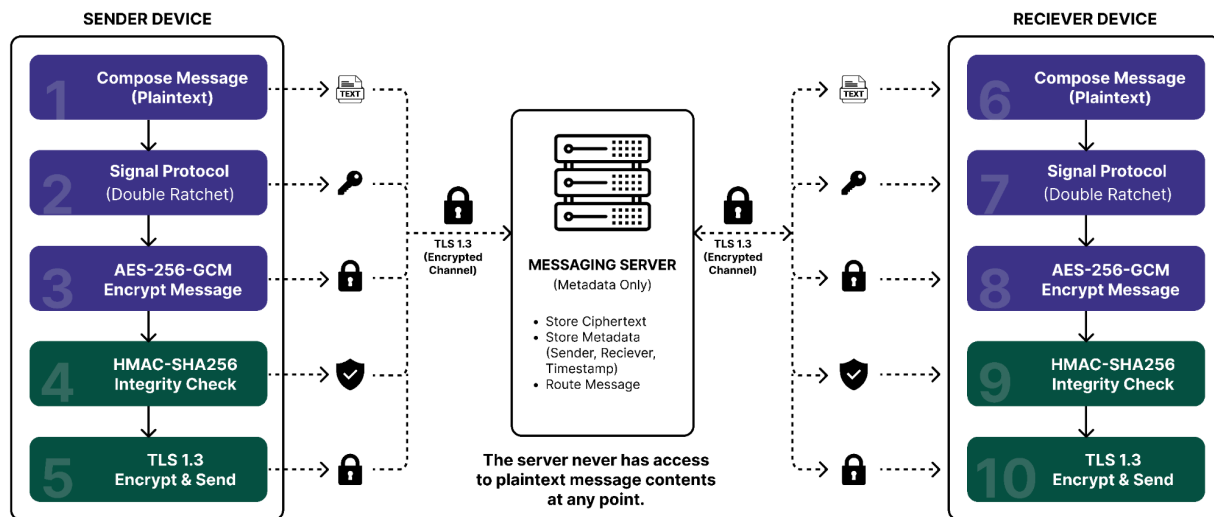
Security Domain	Technology
Messaging	Signal Protocol
File Encryption	AES-256-GCM
Voice Security	SRTP
Transport Security	TLS 1.3
Key Exchange	X3DH
Key Rotation	Double Ratchet
Authentication	MFA + Biometrics
Monitoring	Wazuh + Suricata
Vulnerability Management	OpenVAS

5. Secure Messaging Workflow

This section details the complete flow of a secure text message from sender to receiver.

5.1 Message Encryption and Transmission

Figure 2 – Secure Messaging Workflow



5.2 Step-by-Step Process

1. Sender Initialization
 - a. User opens messaging application
 - b. Client retrieves recipient's public pre-keys from server
 - c. X3DH protocol establishes shared secret with recipient
2. Message Composition
 - a. User types message in plaintext on local device
 - b. Message never transmitted unencrypted
 - c. Message remains in memory during composition
3. Signal Protocol Encryption
 - a. Double Ratchet algorithm derives message key
 - b. Plaintext message encrypted with derived key
 - c. HMAC computed over ciphertext for authentication
4. Transport Layer Security
 - a. Encrypted message wrapped in TLS 1.3 record
 - b. TLS provides additional layer of transport security
 - c. Prevents network-level observation of encrypted payload
5. Server Processing
 - a. Server receives TLS-encrypted payload
 - b. Server cannot decrypt message content
 - c. Server stores only ciphertext and metadata

- d. Server routes message to recipient based on user ID only
- 6. Recipient Decryption
 - a. Recipient's client receives TLS-encrypted message
 - b. TLS layer decrypted at network interface
 - c. Signal Protocol decrypts ciphertext using Double Ratchet
 - d. HMAC verified to ensure message integrity
 - e. Plaintext displayed to recipient

5.3 Encryption Parameters

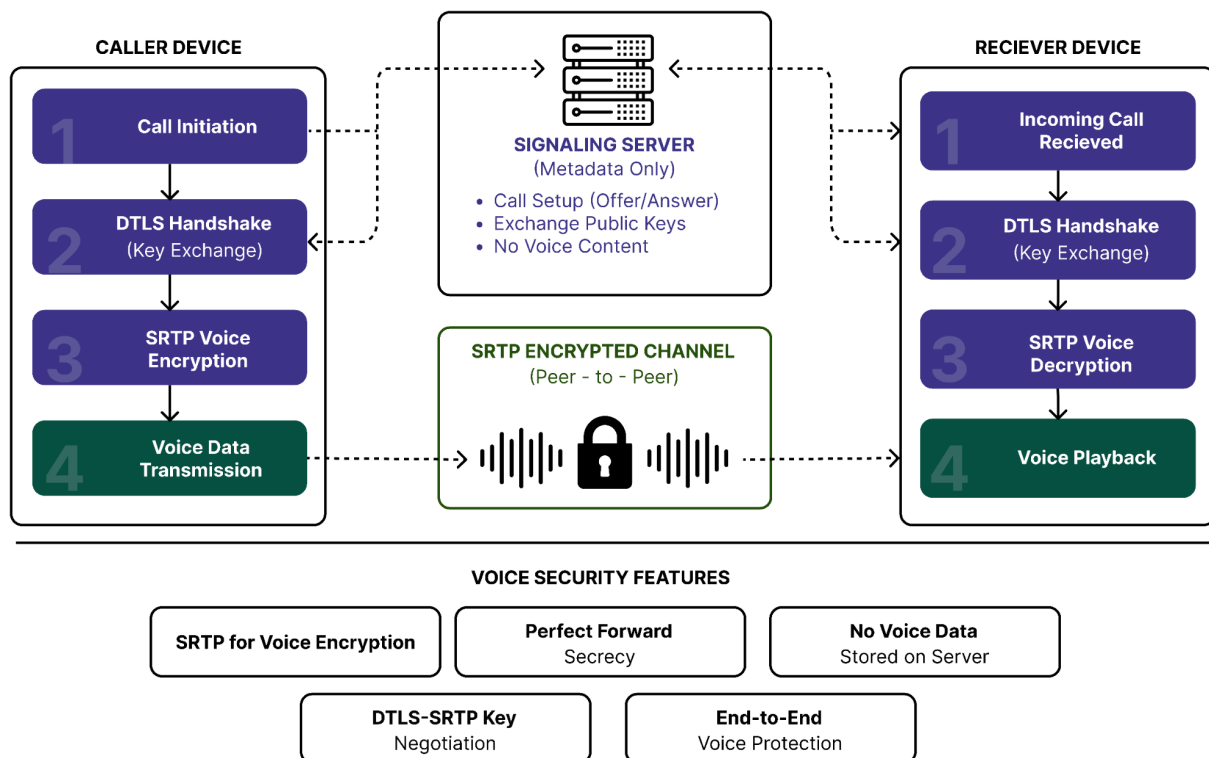
Parameter	Algorithm	Purpose
Symmetric Encryption	AES-256-GCM	Encrypts message content
Integrity Check	HMAC-SHA256	AES-256-GCM provides authenticated encryption, while HMAC-SHA256 may be used for additional integrity verification of metadata and protocol messages.
Key Derivation	Signal Protocol Double Ratchet	Generates unique key per message
Transport Security	TLS 1.3 with ECDHE	Protects data in transit

6. Secure Voice Call Flow

Voice calls are protected using SRTP (Secure Real-time Transport Protocol) for audio encryption and DTLS-SRTP for key exchange.

6.1 Voice Call Encryption

Figure 3 – Secure Voice Call Workflow



6.2 Call Establishment

1. Call Initiation
 - a. Caller initiates call request
 - b. Signaling encrypted with TLS 1.3
 - c. Server relays call invitation to recipient
2. Key Exchange
 - a. Both parties execute DTLS (Datagram TLS) handshake
 - b. Asymmetric keys exchanged for SRTP session keys
 - c. Perfect Forward Secrecy (ECDHE) ensures key ephemeralness
3. Audio Encryption
 - a. Audio frames captured from microphone
 - b. RTP (Real-time Transport Protocol) used for frame packaging
 - c. SRTP encrypts each RTP packet with session key
 - d. Authentication tags computed for integrity

4. Transmission
 - a. Encrypted RTP packets transmitted directly to peer
 - b. Server relay only facilitates NAT traversal
 - c. No decryption or audio access on server
5. Reception and Decryption
 - a. Recipient receives encrypted RTP packets
 - b. SRTP decrypts packets using session key
 - c. Audio frames reassembled from RTP packets
 - d. Audio played through speaker

6.3 Voice Call Parameters

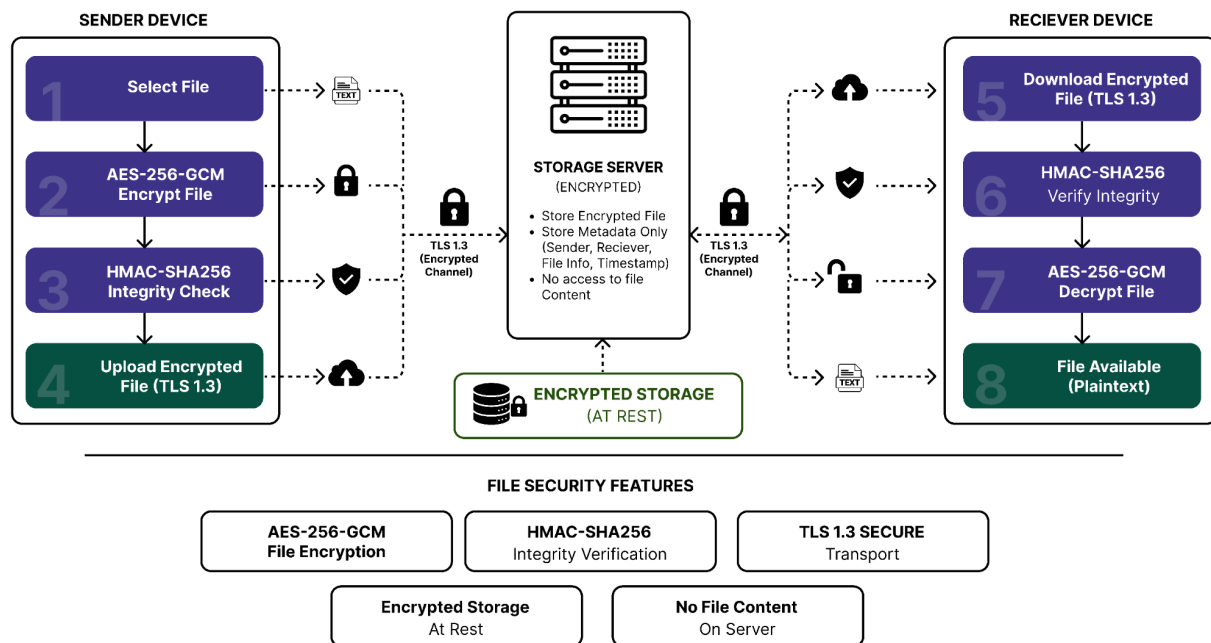
Protocol	Algorithm/Standard	Application
Call Signaling	TLS 1.3	Encrypts call setup and teardown
Key Exchange	DTLS 1.2 with ECDHE	Establishes SRTP session keys
Audio Transport	RTP	Carries audio samples with timestamps
Audio Encryption	SRTP with AES-128 GCM	Encrypts RTP payloads

7. Secure File Transfer Flow

File transfers are encrypted end-to-end using AES-256-GCM with secure key derivation from the Signal Protocol.

7.1 File Encryption Process

Figure 4 – Secure File Transfer Workflow



7.2 File Transmission Procedure

1. File Selection and Preparation
 - a. User selects file from device storage
 - b. File loaded into memory for encryption
 - c. File size and type recorded as metadata
2. Encryption
 - a. Encryption key derived from Signal Protocol session
 - b. File plaintext encrypted with AES-256-GCM
 - c. 96-bit cryptographically secure nonce (IV) randomly generated per message (standard for AES-GCM)
 - d. GCM mode provides authenticated encryption
3. Transport Encryption
 - a. Encrypted file wrapped in TLS 1.3 record
 - b. TLS provides additional transport layer protection
 - c. Chunked transfer for large files
4. Server Storage
 - a. Server receives encrypted file over TLS

- b. File stored in encrypted SQLCipher database
 - c. Encryption key stored separately from file data
 - d. Metadata stored with retention timestamp
- 5. File Download
 - a. Recipient requests file download
 - b. Server retrieves encrypted file from storage
 - c. Encrypted file transmitted over TLS 1.3
 - d. Chunked download for bandwidth optimization
- 6. Decryption
 - a. Recipient's client receives encrypted file
 - b. TLS decryption at network layer
 - c. AES-256-GCM decryption using session key
 - d. HMAC verified for integrity
 - e. Plaintext file reconstructed and stored locally

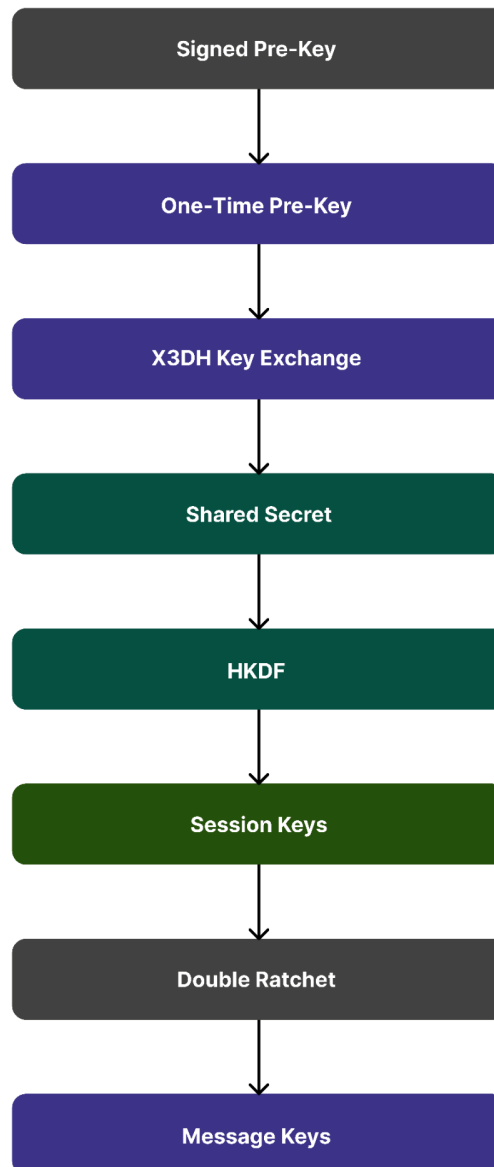
7.3 File Security Parameters

Component	Technology	Purpose
File Encryption	AES-256-GCM	Encrypts file content
IV Generation	CSPRNG	96-bit random nonce (AES-GCM standard)
Server Storage	SQLCipher	Encrypted database for at-rest security
Transport Security	TLS 1.3	End-to-end encrypted channel

8. Key Management Architecture

Effective key management is critical to the security of the entire system. This section details key generation, storage, rotation, and compromise procedures.

Figure 5 – Signal Protocol Key Management Flow



8.1 Key Hierarchy

Key Type	Algorithm	Size	Purpose
Identity Key	X25519	256-bit	Long-term user identity
Pre-Keys	X25519	256-bit	One-time session initiation
Signed Pre-Key	X25519	256-bit	Signed identity proof
Session Keys	Derived via HKDF	256-bit	Per-message encryption
Message Keys	Double Ratchet	256-bit	Individual message encryption

8.2 Key Generation Process

1. User Registration
 - a. User creates account with strong password
 - b. Identity Key Pair generated using cryptographically secure RNG
 - c. Private Identity Key stored securely on device
 - d. Public Identity Key registered with server
2. Pre-Key Generation
 - a. Signed Pre-Key generated and signed with Identity Key
 - b. Minimum of 100 one-time Pre-Keys generated on device
 - c. Pre-Keys uploaded to server for future use
 - d. Server maintains Pre-Key pool and rotates expired keys
3. Session Establishment
 - a. X3DH protocol initiates key exchange between two users
 - b. Shared secret derived from four Diffie-Hellman exchanges
 - c. Initial session key material generated via HKDF

8.3 Key Storage

Key Type	Location	Protection
Private Keys	Device Secure Enclave	Hardware-backed encryption (TEE/Keystore)
Session Keys	Memory (encrypted)	Cleared after use; ephemeral
Message Keys	Derived on-demand	Not stored; generated per message
Public Keys	Server + Device Cache	Signature verification for authenticity

8.4 Key Rotation and Refresh

Periodic key rotation prevents long-term key exposure:

- Signed Pre-Key: Rotated every 7 days
- One-time Pre-Keys: Automatically refreshed when pool drops below 50
- Session Keys: Regenerated for each new conversation
- Message Keys: Unique per message via Double Ratchet

8.5 Compromise Response

In case of suspected key compromise, the following procedures are initiated:

- Immediate Pre-Key rotation across all devices
- User notification of security incident
- Optional manual identity verification with contacts
- All future communications establish fresh keys
- Past messages remain secure due to PFS

9. Security Layers

- The architecture implements a multi-layered security model, where each layer provides independent protection.

9.1 Layer 1: Application Encryption

- Signal Protocol provides end-to-end encryption at the application layer:
 - Encryption keys held only by sender and receiver
 - Server cannot decrypt message content
 - Authentication via HMAC prevents tampering
 - Double Ratchet provides forward secrecy

9.2 Layer 2: Transport Encryption

- TLS 1.3 provides encryption in transit:
 - ECDHE key exchange for Perfect Forward Secrecy
 - AES-256-GCM cipher suite for strong symmetric encryption
 - Mutual authentication via X.509 certificates
 - Prevents network eavesdropping and MITM attacks

9.3 Layer 3: Authentication

- Multi-factor authentication protects user accounts:
 - Password: Argon2id key derivation with per-user salt
 - 2FA: Time-based One-Time Password (TOTP)
 - Biometrics: Fingerprint or Face recognition (device-backed)
 - Prevents unauthorized account access

9.4 Layer 4: At-Rest Encryption

- Data stored on devices and servers is encrypted:
 - SQLCipher: Encrypted local database on devices
 - Full Disk Encryption: Device storage protection
 - Server Storage: Encrypted database with key management
 - Backup Encryption: Encrypted backups with user-controlled keys

9.5 Layer 5: Authorization and Access Control

- Role-Based Access Control (RBAC) restricts system access:

Role	Permissions
End User	Send/receive messages, initiate calls, transfer files
Moderator	Monitor group conversations, mute users, remove inappropriate content
Administrator	Full system access, user management, security configuration, incident response

9.6 Security Validation and Testing

- The following security testing framework validates architectural implementation:
Security Testing Tools and Objectives

Tool	Purpose	Validation Focus
MobSF (Mobile Security Framework)	Mobile application security assessment	App permissions, encryption configuration, secure storage
Burp Suite Community Edition	Web and API security testing	TLS 1.3 cipher suite verification, certificate validation
Wireshark	Network protocol analysis	Encrypted traffic verification, no plaintext transmission
Frida	Runtime instrumentation	Key exchange verification, encryption function calls
OpenVAS	Vulnerability scanning	Server configuration, patch levels, known CVEs

- **Validation Objectives:** The following validation procedures confirm security controls are functioning:
 - Message Encryption:
 - Verify all messages are encrypted end-to-end with Signal Protocol
 - TLS Verification:
 - Confirm TLS 1.3 usage with PFS-enabled cipher suites
 - SRTP Protection:
 - Validate voice calls use SRTP encryption
 - Key Exchange Security:
 - Confirm X3DH and Double Ratchet implementation
 - Secure Storage:
 - Verify SQLCipher encryption on client and server databases

- Authentication: Validate MFA implementation and biometric integration
- RBAC Enforcement:
 - Confirm role-based access control enforcement
- **Expected Test Evidence:** Security testing produces the following evidence artifacts:
 - MobSF scan reports showing encryption configurations
 - TLS handshake captures showing cipher suite negotiation
 - Wireshark packet analysis showing encrypted payloads
 - SRTP traffic captures demonstrating audio encryption
 - Frida inspection showing cryptographic function execution
 - Database integrity verification confirming encryption at rest
- These validation procedures are executed in Deliverable 7 (Monitoring & Incident Response) with captured evidence.

9.7 Layer 6: Monitoring and Detection

- Continuous security monitoring detects and responds to threats:
 - Host Monitoring: Wazuh agent monitors system logs
 - Intrusion Detection: Suricata monitors network traffic
 - Vulnerability Scanning: OpenVAS identifies misconfigurations
 - Packet Analysis: Wireshark captures and analyzes protocols

10. Future Enhancements and Security Evolution

- While the current architecture provides robust protection, the following enhancements are recommended for future iterations:
- Post-Quantum Cryptography
 - Integrate NIST-standardized post-quantum algorithms (Kyber for key exchange, Dilithium for signatures)
 - Ensures longevity against potential quantum computing threats
 - Expected adoption: 2027-2030 based on NIST timeline
- Secure Multi-Party Messaging
 - Implement group encryption with individual key derivation
 - Enable secure group conversations with forward secrecy per participant
 - Support dynamic group membership changes
- Metadata Obfuscation
 - Implement secondary anonymization layer (Tor integration for traffic)
 - Reduce metadata visibility to network observers
 - Reference: Briar Project metadata anonymization approach
- Decentralized Identity
 - Integrate Decentralized Identifiers (DIDs) for user identity
 - Enable portable identity verification across platforms
 - Support self-sovereign identity principles
- Confidential Computing
 - Migrate sensitive operations to TEEs (Intel SGX, ARM TrustZone)
 - Protect key derivation and decryption operations in isolated environments
 - Minimize plaintext exposure in untrusted memory
- Security Standards Evolution
 - Monitor evolving standards and adapt implementation accordingly:
 - NIST SP 800-57 (Cryptographic Key Management)
 - RFC 8446 (TLS 1.3 updates and variants)
 - FIDO Alliance standards for passwordless authentication
 - ETSI standards for end-to-end encryption requirements

11. Conclusion

- This Updated Security Architecture Document provides a comprehensive framework for protecting messaging application communications through multiple layers of encryption, authentication, and monitoring.

11.1 Key Achievements

- End-to-end encryption for all communication types (messaging, voice, files)
- Signal Protocol implementation with proven security properties
- Perfect Forward Secrecy via Double Ratchet algorithm
- Multi-factor authentication with biometric support
- Minimal data retention policies protecting user privacy
- Comprehensive monitoring and incident response capabilities

11.2 Implementation Roadmap

- Subsequent deliverables will detail the specific implementation procedures for each component outlined in this architecture document, including:
 - Encryption Integration Plan with configuration steps
 - Authentication & Authorization implementation guide
 - Secure communication channel configuration
 - Privacy and data retention policy documentation
 - Monitoring and incident response procedures
 - User awareness training materials

11.3 Security Assurance

- This architecture provides defense-in-depth security through:
 - Proven cryptographic algorithms (AES-256, SHA-256, X25519)
 - Battle-tested protocols (Signal Protocol, TLS 1.3, SRTP)
 - Industry best practices (zero-knowledge, privacy-by-design)
 - Regular security audits and vulnerability assessments
 - Continuous monitoring and threat detection
 - Incident response procedures for rapid threat mitigation
- Implementation of this security architecture ensures that users can communicate with confidence, knowing their conversations are protected by world-class encryption and security practices.

APPENDIX A – Security Standards and Specifications Mapping

- This appendix maps architectural components to industry standards and specifications:

Standards Compliance Matrix

Architectural Component	Applicable Standard	Reference	Purpose
Encryption Key Management	NIST SP 800-57	Key Establishment Procedures	Defines key lifecycle management and rotation
TLS 1.3 Implementation	RFC 8446	Hypertext Transfer Protocol (HTTP) over TLS	Specifies TLS 1.3 protocol and cipher suites
SRTP Voice Encryption	RFC 3711	The Secure Real-time Transport Protocol	Defines SRTP encryption and authentication
Signal Protocol Implementation	Open Whisper Systems Signal Protocol Specification	Signal Protocol Documentation	Specifies X3DH key exchange and Double Ratchet algorithm
Multi-Factor Authentication	NIST SP 800-63B	Digital Identity Guidelines - Authentication and Lifecycle Management	Defines MFA requirements and TOTP standards
Password Hashing	OWASP Password Storage Cheat Sheet	OWASP Reference	Specifies Argon2id for password derivation
X.509 Certificates	RFC 5280	Internet X.509 Public Key Infrastructure	Defines TLS certificate standards
HMAC Authentication	FIPS 198-1	Keyed-Hash Message Authentication Code (HMAC)	Specifies HMAC computation and verification
AES Encryption	FIPS 197	Advanced Encryption Standard (AES)	Defines AES-256-GCM algorithm specifications
Biometric Authentication	ISO/IEC 30107	Biometric Presentation Attack Detection	Defines spoofing resistance requirements

- This mapping demonstrates alignment with internationally recognized security standards and provides a foundation for compliance audits and certifications.

APPENDIX B – Glossary

- **AES-256-GCM:**
 - Advanced Encryption Standard with 256-bit key length and Galois/Counter Mode for authenticated encryption
- **DTLS:**
 - Datagram Transport Layer Security
 - TLS variant for UDP-based protocols
- **DH:**
 - Diffie-Hellman key exchange protocol
- **ECDHE:**
 - Elliptic Curve Diffie-Hellman Ephemeral key exchange
- **HMAC:**
 - Keyed-Hash Message Authentication Code for message authentication
- **MFA:**
 - Multi-Factor Authentication (passwords, TOTP, biometrics)
- **PFS:**
 - Perfect Forward Secrecy
 - past communications remain secure even if long-term keys are compromised
- **RBAC:**
 - Role-Based Access Control
- **RTP:**
 - Real-time Transport Protocol for audio/video
- **Signal Protocol:**
 - End-to-end encryption protocol using X3DH and Double Ratchet
- **SRTP:**
 - Secure Real-time Transport Protocol (encrypted RTP)
- **TEE:**
 - Trusted Execution Environment (Secure Enclave, ARM TrustZone)
- **TLS 1.3:**
 - Transport Layer Security version 1.3
- **X3DH:**
 - Extended Triple Diffie-Hellman key exchange protocol
- **X25519:**
 - Elliptic curve Diffie-Hellman primitive for 256-bit keys